



WORDPRESS

# EL COSTE DE UN HACKEO

Por Néstor Angulo de Ugarte

# Néstor Angulo de Ugarte

- Ingeniero informático (ULPGC)
- CISSP (ISC2.org)

**Analista de Seguridad**

@ GoDaddy WebSecurity

@ Sucuri.net

**Software Engineer**



X (Twitter): @pharar



## DISCLAIMER

**NO** soy abogado, ni contable

**NO** vengo a publicitar a ninguna empresa en esta charla.

**Soy responsable de lo que digo, no de lo que interpretas.**



SPOILER  
ALERT



- Dashboard
- All in One SEO
- Jetpack
- Unyson
- Blog Posts
- Media
- Pages
- Comments
- Forms
- FooGallery
- Portfolio
- Feedback
- Forms

- Appearance
- Plugins
- Users

- All Users
- Add New

# Users [Add New](#)

Welcome to the newest version of WP Smush! Auto-smushing on upload is lightning fast now that we handle all the smushing asynchronously. [Find out more here >>](#)

All (5) | [Administrator \(3\)](#) | [Contributor \(2\)](#)

[Search Users](#)

[Bulk Actions](#) [Apply](#) [Change role to...](#) [Change](#)

6 items

| <input type="checkbox"/>            | Username                                                                                                        | Name                             | Email                    | Role          | Posts |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------|--------------------------|---------------|-------|
| <input type="checkbox"/>            |  admin                         |                                  |                          | Administrator | 78    |
| <input checked="" type="checkbox"/> |  akmin                         |                                  | no@email.com             | Administrator | 1     |
| <input type="checkbox"/>            |  janel                         |                                  |                          | Contributor   | 0     |
| <input type="checkbox"/>            |  levy                          |                                  |                          | Contributor   | 33    |
| <input checked="" type="checkbox"/> |  managed-wp-migration-465790ae | Managed WordPress Migration User | noreply@secureserver.net | Administrator | 0     |

Administradores sospechosos...

| <input type="checkbox"/> |  wp.service.controller |      |       | None | 0     |
|--------------------------|---------------------------------------------------------------------------------------------------------|------|-------|------|-------|
| <input type="checkbox"/> | Username                                                                                                | Name | Email | Role | Posts |

[Bulk Actions](#) [Apply](#) [Change role to...](#) [Change](#)

6 items



## Title

Hacked By **BALA SNIPER**

Hacked By **GeNErAL**

## Content

<p>Hacked By BALA SNIPER<br />

Kurdish Hacker Here<br />

If you want Fix Problem Website &#8230; !<br />

Contact Me via Gmail : darinsniper007@ gmail.com<br />

Contact Me Via Facebook : <https://www.facebook.com/balasniper007> </p>

```
<title>~!Hacked By GeNErAL alias Mathis!~</title>
<h2>Hacked By GeNErAL</h2>&nbsp;</font></p><img
border='0' src='http://www.officialpsds.com/images/thumbs
/Baby-Devil-Toon-psd9848.png'><br><br><br><b>Greetz :
Kuroi'SH, RxR, ~ </b><br><br></FOOTER><b><code>
<h1>~!Just for Fun ~Hacked By GeNErAL~!</code>
```

```
<div align='center'><font color='red' /><font
size='5' color='#FF0000'>Hacked By
GeNErAL! !</font></font></div>
```

Tus posts cambian...

Hacked by El Moujahidin



#Free Syria  
#Free Palestine

Tell Your Gov , To Know About  
We Will Countinue Hacking The Sites , To Send The Message  
We Dont Accept Killing Muslims Evry Where  
#We Are El Moujahidin Team We Will Not Stop  
#AttaCker fr0m #Algeria



HACKED By m4g!c\_mUn5h!

(Cyb3R\_Sw0rD Hacking Group Form Bangladesh)

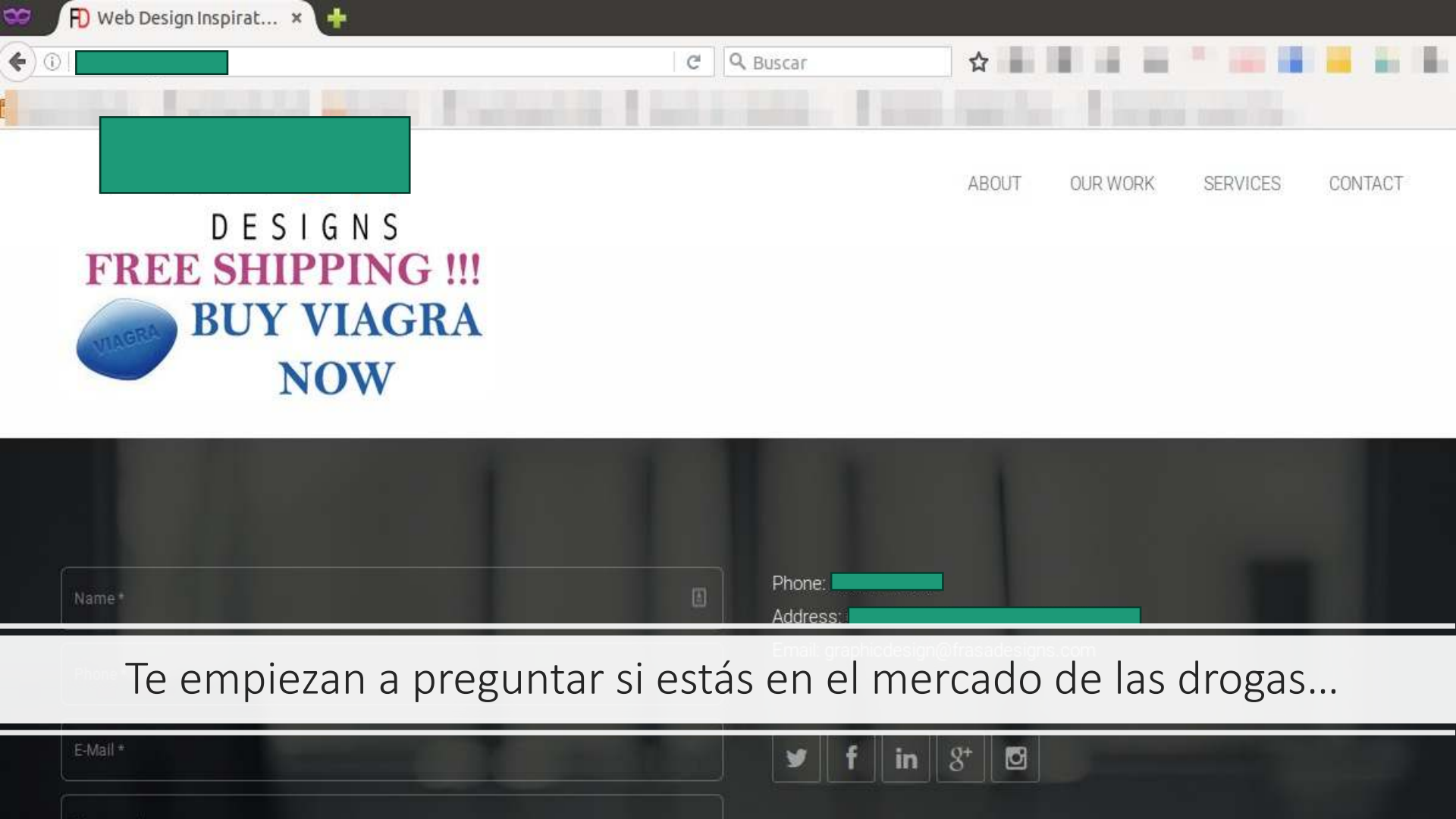
(Security Doesn't Exit Our Dictionary...)

(Feel The Power Of Cyb3R\_Sw0rD...)

SH0t3z : B!4CK\_C0D3R | H4xor\_injector | R3D C0D3R | All Member Cyb3R\_Sw0rD

Tu página de  
inicio cambia  
"ligeramente"





DESIGNS  
**FREE SHIPPING !!!**  
 **BUY VIAGRA  
NOW**

Name \*

Phone:

Address:

Email: [graphicdesign@frasadesigns.com](mailto:graphicdesign@frasadesigns.com)

Phone: Te empiezan a preguntar si estás en el mercado de las drogas...

E-Mail \*





| Remote site: /public_html/wp-content/plugins |          |
|----------------------------------------------|----------|
| Filename ^                                   | Filesize |
| ..                                           |          |
| Login-wall-KiLxb                             |          |
| Login-wall-NUJIF                             |          |
| advanced-custom-fields                       |          |
| all-in-one-wp-security-and-firewall          |          |
| alltimeusdflowingin                          |          |
| contact-form-7                               |          |
| disable-comments                             |          |
| google-sitemap-generator                     |          |
| joomjs                                       |          |
| js_composer                                  |          |
| page-links-to                                |          |
| really-simple-captcha                        |          |
| sucuri-scanner                               |          |
| wordfence                                    |          |
| wordpress-seo                                |          |
| wp-pagenavi-master                           |          |
| hello.php                                    | 24313    |
| index.php                                    | 28       |

| Remote site: /public_html/wp-content/plugins/joomjs |      |
|-----------------------------------------------------|------|
| Filename                                            | File |
| ..                                                  |      |
| _inc                                                |      |
| views                                               |      |
| index8632.php                                       |      |
| joomjs.php.suspected                                |      |
| index.php                                           |      |
| akismet.php                                         |      |
| class.akismet-widget.php                            |      |
| error_log                                           |      |
| readme.txt                                          |      |
| wrapper.php                                         |      |
| class.akismet-admin.php                             | 3    |
| class.akismet.php                                   | 3    |



# Account Suspended

**This Account has been suspended.**

Contact your hosting provider for more information.



## The site ahead contains harmful programs

Attackers on  might attempt to trick you into installing programs that harm your browsing experience (for example, by changing your homepage or showing extra ads on sites you visit).

☒ Automatically report details of possible security incidents to Google. [Privacy policy](#)

[Details](#)

[Back to safety](#)



site:anotherinfectedsite.dom cheap



All

Images

Shopping

Videos

Maps

More ▾

Search tools

About 91,300 results (0.31 seconds)

**Cheap Nike Shox Boys 6.5 23 Air Jordan Comforters ...**

[anotherinfectedsite.dom/page/lvUxxxp1D](#) ▾

cheap nike shox boys 6.5. Shop our premium selection of boys nike shox turbo online now for great prices. Boys' toddler nike air max 90 premium running shoes.

**Air Yeezy Shoes Cheap Real Air Yeezy Shoes - Natural ...**

[anotherinfectedsite.dom/page/lpNxxxxx58vuK](#) ▾

Results great but cheap air yeezy shoe,cheap shoes,men's casual shoes,women's casual shoes,men's flats,as well as cheap and more online get.Size 6 nike air ...

**Cheap Jordan Sneakers Wholesale Cheap Jordan Website ...**

[anotherinfectedsite.dom/page/lv1CxxxxxIQVH](#) ▾

Cheap jordan sneakers wholesale we cheap jordan sneakers wholesale are a cheap jordan website large wholesaler cheap wholesale nike dunks and retailer ...

**Example Domain**

[www.example.com/](#) ▾

**This site may be hacked.**

Example Domain. This domain is established to be used for illustrative examples in documents. You may use this domain in examples without prior coordination or asking for permission. More information...

## Not eligible

Ad disapproved due to:

❗ Malicious or unwanted software

- [Read the policy](#)

[Appeal](#)

[Edit ad](#)



Ad

Campaign

Ad group

Status

[Your Website Ad | Advertising for Revenue](#)

[example.com](#)

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna.

[Example Campaign](#)

[Example Ad Group](#)

**Disapproved**  
Malicious or unwanted software



## Google Membership Rewards



### Congratulations

January 26 at 12:03am

Every Tuesday we select 10 lucky Apple users as our sponsors. This free gift is **exclusively** for our continuous support for our product and services.

You have been selected to win a gift from [redacted] worth up to \$749 if you answer the next 4 questions correctly.

**ACT NOW! 9 other Apple users have received this invitation with only 5 prizes to win.**

You have **1 minutes 30 seconds** to answer the questions before someone else takes over your spot. Good luck!

The page at promotion.com-rewards.club says: ✕

Congratulations iPad user!

You are selected by Google to be among the first few persons to win an iPhone 6s or other Google prizes! This free gift is exclusively only for loyal Apple users in Canada.

Please confirm that you are the owner of this iPad phone by clicking OK.

OK



### Google Gift!

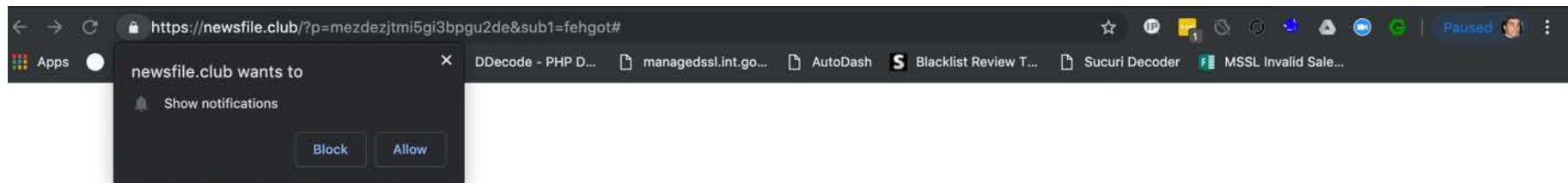
[redacted] (d!) from [redacted]  
is just our way to thank you for your

### Question 1 of 4: Who founded Google?

Bill Gates

Mark Zuckerberg

Larry Page











## This site can't be reached

**nogluten.com**'s server IP address could not be found.

DNS\_PROBE\_FINISHED\_NXDOMAIN

Reload





PHISHING

BOTNET

SPAM

HACKER

MALWARE

DDOS

VIRUS

KEYLOGGER

SPYWARE

Te toca la puerta la  
policía...

---

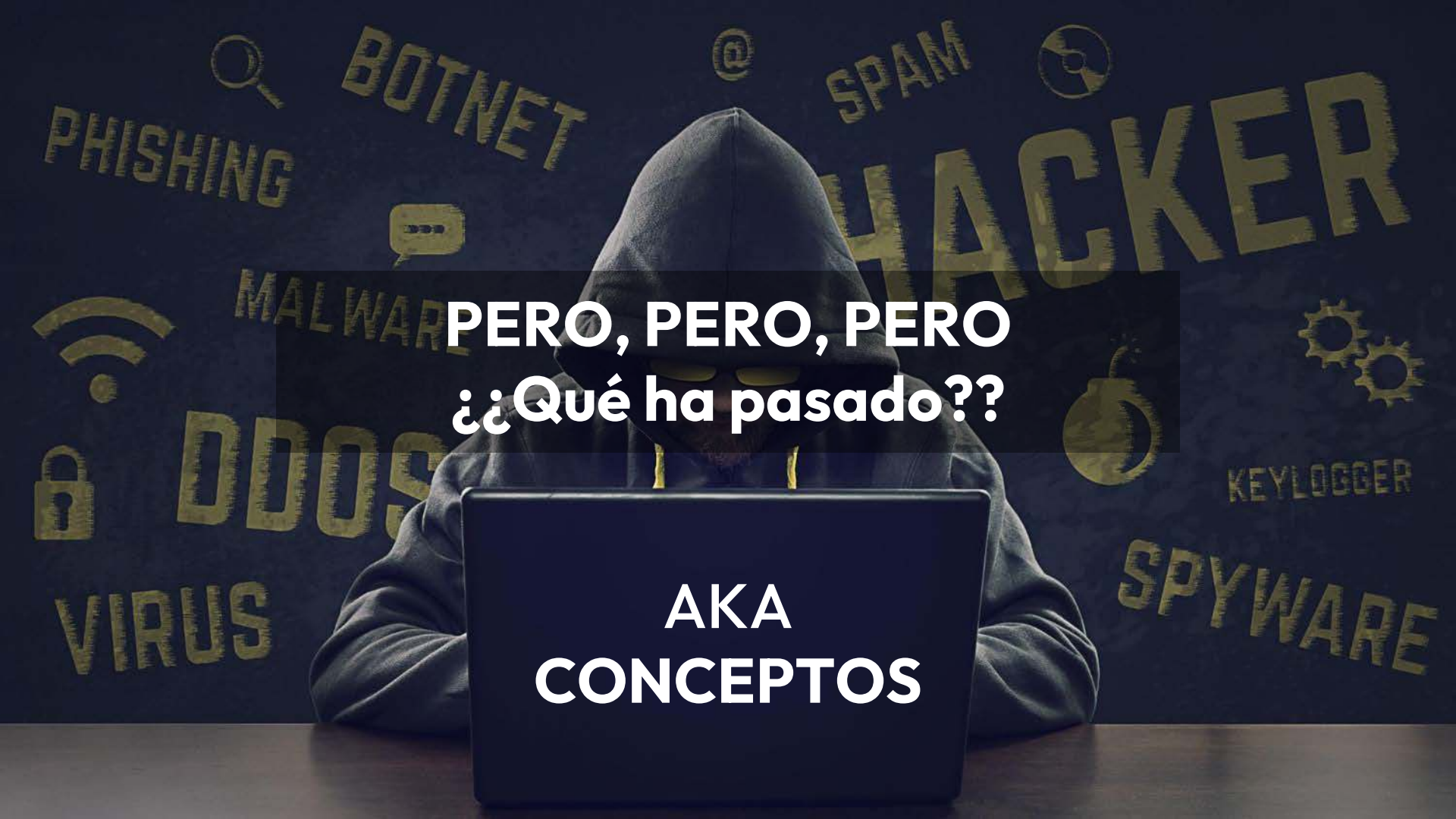


A man with a beard, wearing a black polo shirt, is holding a silver laptop. The laptop screen is black with the text 'YOU'VE BEEN HACKED!' in a green, monospaced font. The man's face is partially visible at the top of the frame. The background is dark and out of focus.

YOU'VE BEEN HACKED!

MacBook Pro





**PERO, PERO, PERO**  
**¿¿Qué ha pasado??**

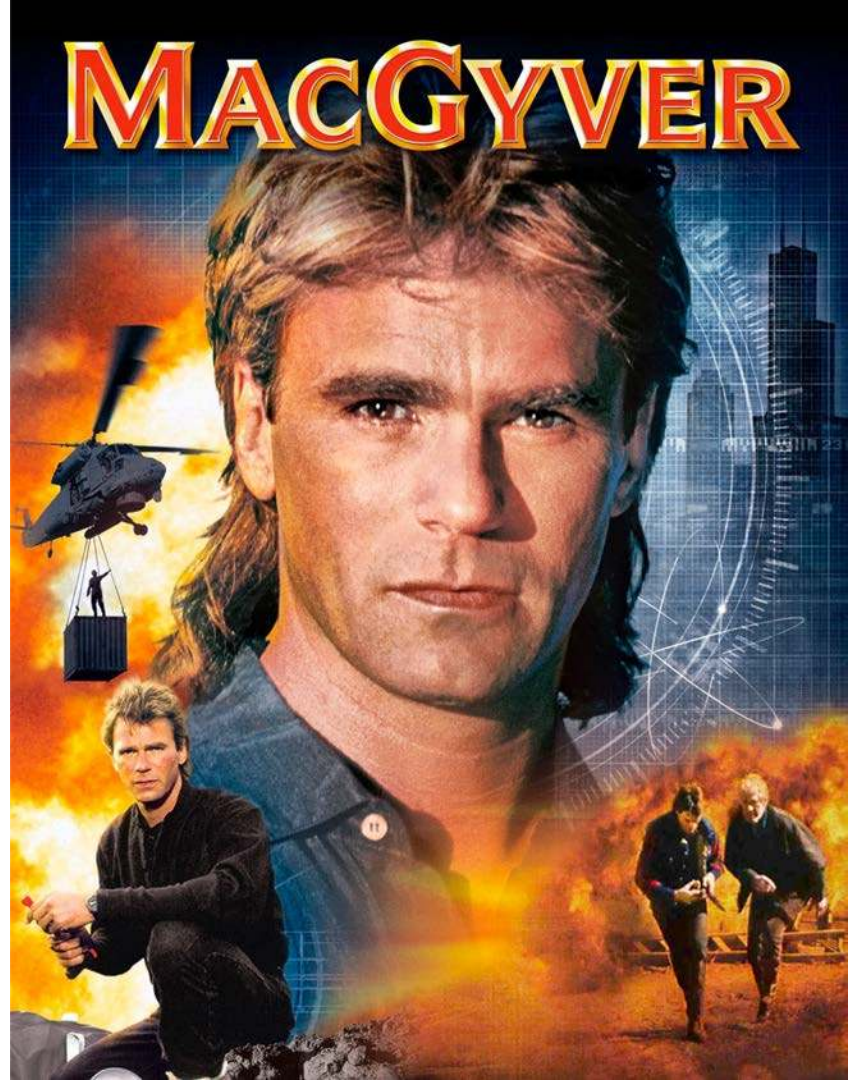
**AKA**  
**CONCEPTOS**



# ¿Hackers?

Persona **curiosa** que va  
más allá de límites y  
convencionalismos

**AKA Hacker**









- Thales de Mileto
- Hipatia de Alejandría
- Leonardo da Vinci
- Thomas Edison
- Arquímedes
- Marie Curie
- Louis Pasteur y Alexander Fleming
- Hedy Lamarr
- Nikola Tesla
- Grace Hopper y Ada Lovelace



# ¿Entonces a qué le llamamos Hacker?



**Hacker informático**  
cuyo objetivo es  
enriquecerse o ganar  
fama.

**AKA Ciberterrorista**





MR.

ROBOT

USA



## **El Malo**

Black hat hacker,  
terrorista,  
ladrón,  
ciberdelicuenta...

## **El Feo**

Un Bueno usando  
métodos de Malo

## **El Bueno**

Analista de  
seguridad,  
hacker ético...



El Black hat  
terrorista,  
ladrón,  
ciberdelicuenta...

El White hat  
hacker ético...



**El Mal**  
**Black hat**  
**terrorista,**  
**ladrón,**  
**ciberdelicuenta...**

**Metodos de Malo**  
**seguridad,**  
**hacker ético...**





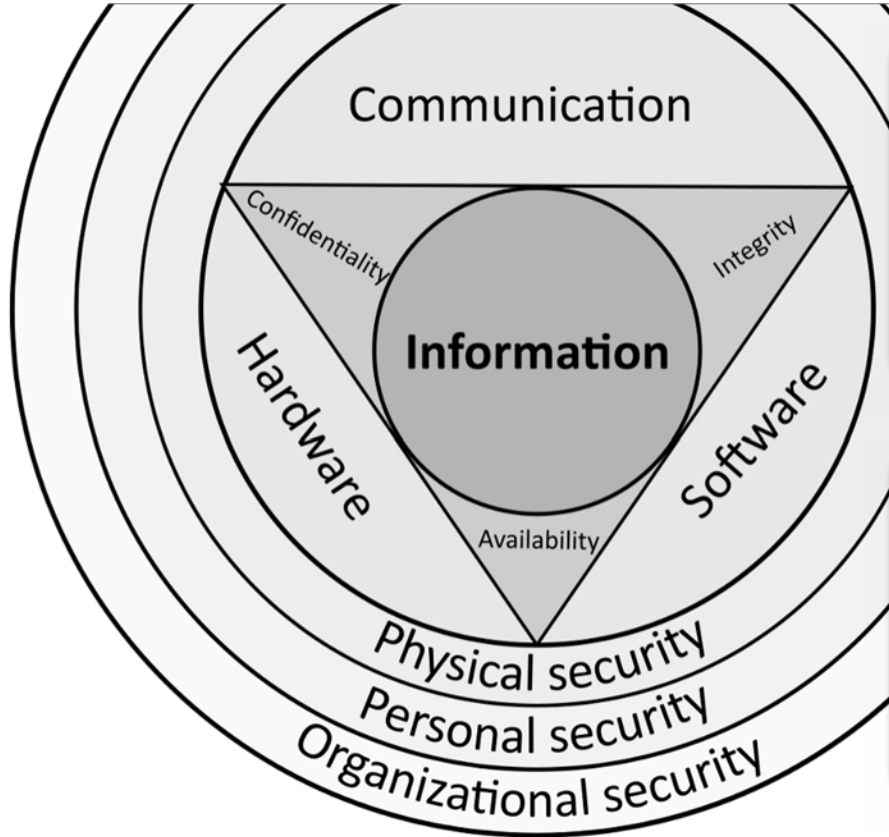
**¡Los Analistas  
de Seguridad, son  
los que hackean  
bonito!**



A photograph of a brick wall densely populated with security cameras. The cameras are arranged in a grid-like pattern, with some black and some silver. A dark vertical rectangular feature, possibly a window or door frame, is visible in the upper center. At the bottom of the frame, two women are standing on a sidewalk, looking up at the wall of cameras. The woman on the left is wearing a dark jacket and black pants, while the woman on the right is wearing a brown leather jacket and blue jeans. A dark door is visible on the right side of the wall.

**¿Qué es CIBERSEGURIDAD?**

# ¿Qué es InfoSec?



## CIA Triad

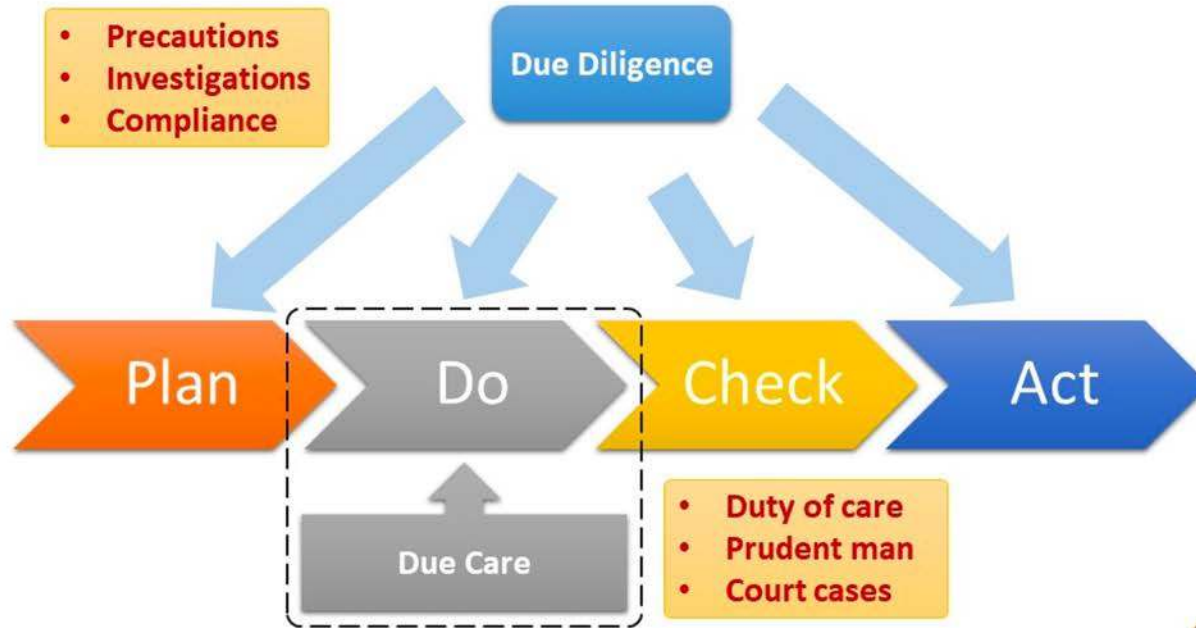
- Confidentiality
- Integrity
- Availability

## DAD Triad

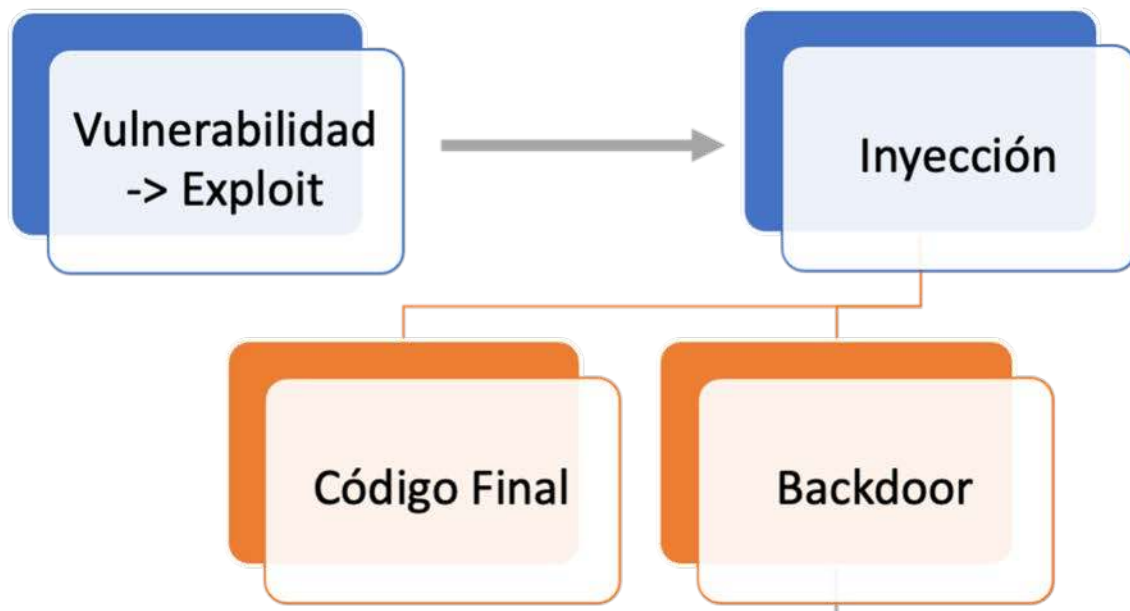
- Disclosure
- Alteration
- Destruction

# Ser diligente y tomar acciones

## Due Diligence and Due Care



# Cómo se hackea un WordPress



A 3D perspective illustration of a data breach. The words "DATA" and "BREACH" are rendered in large, blocky, 3D letters. "DATA" is white, and "BREACH" is red. Above the word "DATA", a red 3D crown is shown being crushed by several white, angular, geometric shapes that resemble shards or fragments. The entire scene is set within a white, recessed rectangular frame that has a slight depth, with shadows indicating a light source from the upper left. The background outside the frame consists of white and gray geometric shapes, suggesting a larger architectural or digital environment.

**DATA**  
**BREACH**





## ¿Qué ES una brecha de datos?

**GDPR:** “todas aquellas **violaciones de la seguridad** que ocasionen la **destrucción, pérdida o alteración** accidental o ilícita de **datos personales** transmitidos, conservados o tratados de otra forma, o **la comunicación o acceso no autorizados** a dichos datos”.

## ¿Qué NO ES una brecha de datos?

Un **incidente de seguridad que no ha afectado a datos personales o tratamientos de datos personales** no es una brecha de datos personales, dado que **no podría producir daños sobre los derechos y libertades de las personas físicas** cuyos datos son objeto del tratamiento, independientemente de otros perjuicios que pueda producir al responsable o encargado del tratamiento.

# ¿Qué significa daños o perjuicios?

## Consecuencias para los afectados

Imposibilidad de ejercer algún derecho o acceso a un servicio

Usurpación de la identidad

Víctima de campañas de phishing/spamming

Pérdidas financieras

Daños reputacionales

Pérdida de confidencialidad de datos afectados por secreto profesional

Daños psicológicos o físicos

Pérdida de control sobre sus datos personales

# Perfiles de personas físicas

---

| <b>Perfiles de las personas físicas afectadas</b> |
|---------------------------------------------------|
| Clientes / ciudadanos                             |
| Estudiantes / alumnos                             |
| Usuarios                                          |
| Pacientes                                         |
| Suscriptores / potenciales clientes               |
| Afiliados / asociados                             |
| Fuerzas y Cuerpos de Seguridad del Estado         |
| Empleados                                         |
| Otros                                             |



# ¿Qué se consideran datos sensibles?

| Categorías de datos                                                                                               | Significado                                                                                                                                               |
|-------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Datos básicos                                                                                                     | Nombre, apellidos o la fecha de nacimiento de los afectados                                                                                               |
| Datos de contacto                                                                                                 | Número de teléfono, email o dirección física de las personas                                                                                              |
| Imágenes (foto/video)                                                                                             | Imágenes individuales o colectivas de las personas afectada                                                                                               |
| Documento identificativo                                                                                          | NIF, NIE, pasaporte, número de Seguridad Social o cualquier otro identificador a nivel nacional o extra nacional                                          |
| Datos económicos o financieros                                                                                    | Datos referidos a nóminas, extractos bancarios, estudios económicos o cualquier otra información que pueda revelar información económica de los afectados |
| Datos de localización (datos de ubicación de la persona en un determinado momento o durante un periodo de tiempo) | Datos de posicionamiento, coordenadas o direcciones habituales (no residencia) de los afectados                                                           |
| Medios de pago (números de tarjeta o cuenta bancaria)                                                             | Información de los afectados referido a métodos de pago como números de tarjeta, cuentas bancarias, métodos de pago online como Paypal, bitcoins, etc.    |
| Credenciales de acceso o identificación                                                                           | Nombres de usuarios, contraseñas ya estén en claro, hashadas o cifradas y datos como tarjetas de coordenadas o segundos factores de autenticación         |
| Datos de perfiles                                                                                                 | Perfiles de usuarios en redes o datos de perfilado psicosocial o que permitan realizar perfilados de personas físicas                                     |
| Sobre la vida sexual                                                                                              | Datos relativos a la salud sexual, hábitos, orientación o tendencias sexuales, así como información que permita inferirlo.                                |

# ¿Qué se consideran datos sensibles?

|                                                    |                                                                                                                                                                                                                            |
|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Religión o creencias</b>                        | Religión que profesan los afectados, así como información sobre posturas religiosas, agnósticas o ateas                                                                                                                    |
| <b>Origen racial o étnico</b>                      | Información que refleje o permitan establecer el origen racial o la pertenencia a una determinada etnia de las personas                                                                                                    |
| <b>Datos de salud de empleados</b>                 | Información sobre la salud que un responsable trate sobre sus empleados o personas con las que mantiene una relación laboral, como puedan ser partes de baja o informes sanitarios                                         |
| <b>Datos de salud de pacientes</b>                 | Referido a la información que los responsables del sector sanitario dispongan de las personas                                                                                                                              |
| <b>Opinión política</b>                            | Información que refleje o permita averiguar la opinión o tendencias políticas de las personas                                                                                                                              |
| <b>Datos genéticos</b>                             | Características genéticas heredadas o adquiridas de una persona física que proporcionen una información única sobre la fisiología o la salud de esa persona, obtenidos en particular del análisis de una muestra biológica |
| <b>Datos sobre condenas e infracciones penales</b> | Certificados de antecedentes penales o los certificados de delitos de naturaleza sexual                                                                                                                                    |
| <b>Datos biométricos</b>                           | Características físicas, fisiológicas o conductuales de una persona física, que permita su identificación                                                                                                                  |
| <b>Datos sobre afiliación sindical</b>             | Informan sobre la pertenencia o afiliación de una persona a un sindicato                                                                                                                                                   |

# OBLIGADO, si hay una Brecha de Datos

- **Comunicar** a la autoridad competente (España/Europa es la AEPD) en **menos de 72h** desde que se tiene constancia de la brecha.
- Hacer una **valoración de riesgo** para las personas afectadas **y de alcance** de la brecha.

| Probabilidad | Muy alta                 | <div>Obligación<br/>Comunicar<br/>Afectados</div> |                  |                      |                              |
|--------------|--------------------------|---------------------------------------------------|------------------|----------------------|------------------------------|
|              | Alta                     |                                                   |                  |                      |                              |
|              | Baja                     |                                                   |                  |                      |                              |
|              | Improbable <sup>34</sup> | Comunicar afectados                               |                  |                      |                              |
|              |                          | Baja - Muy limitada                               | Media - Limitado | Alta - Significativo | Muy alta - Muy significativo |
|              |                          | Severidad (Gravedad del impacto)                  |                  |                      |                              |



# EJEMPLO 1

## Blog + Newsletter

---



# Datos que se recopilan

- Subscribers/leads
  - Nombres y apellidos
  - Correo
  - Teléfono¿?
  - Cargo¿?
  - Empresa¿?
  - Edad¿?
- Cookies / Analíticas
- Usuario y contraseña





# Ingresos - Costes -> Beneficios:

**1.000€ - 4.000€**

| Paquete   | Concepto            | Precio (rango) | Cantidad  | Total           | Notas                             |
|-----------|---------------------|----------------|-----------|-----------------|-----------------------------------|
| Sitio Web | Hosting + dominio   | 100€ - 200€    | 1         | 100€ - 200€     |                                   |
|           | Diseño              | 0€ - 3.000€    | 1         | 0€ - 3.000€     |                                   |
|           | Plugins / servicios | 0€ - 200€      | 1         | 0€ - 200€       | SEO,<br>Newsletter,<br>forms...   |
| TIEMPO    | Hora de dedicación  | 20€            | 300 - 450 | 6.000€ - 9.000€ |                                   |
| Ingresos  | Reputación          | 10.000€        | 1         | 10.000€         | Consultoría,<br>afiliados, ads... |

## Y qué pasa si te hackean...

| Concepto                         | Tipo           |
|----------------------------------|----------------|
| Entender qué ha pasado           | Tiempo         |
| Implementar Medidas de Seguridad | Tiempo, Dinero |
| Servicio para limpiar el sitio   | Tiempo, Dinero |
| Comunicación a la AEPD < 72h     | Tiempo         |
| Estudio de riesgo e impacto      | Tiempo         |

## Y si la severidad del hackeo es alta...

| Concepto                                                               | Tipo           |
|------------------------------------------------------------------------|----------------|
| Notificar a clientes / Usuarios                                        | Tiempo         |
| Lidiar con las quejas y comunicaciones (Demandas?)                     | Tiempo/Dinero  |
| <b>Estrés</b>                                                          | Tiempo, Dinero |
| <b>Multa GDPR</b> ( $\leq 20.000\text{€}$ ), si siguen el protocolo    | Tiempo, Dinero |
| <b>Multa GDPR</b> ( $\leq 40.000\text{€}$ ), si no siguen el protocolo | Tiempo, Dinero |

# Ingresos - Costes -> Beneficios: - (14.000€ - 22.000€)

| Paquete   | Concepto            | Precio (rango) | Cantidad   | Total             | Notas                          |
|-----------|---------------------|----------------|------------|-------------------|--------------------------------|
| Sitio Web | Hosting + dominio   | 100€ - 200€    | 1          | 100€ - 200€       |                                |
|           | Diseño              | 0€ - 3.000€    | 1          | 0€ - 3.000€       |                                |
|           | Plugins / servicios | 0€ - 200€      | 1          | 0€ - 200€         | SEO, Newsletter, forms...      |
| TIEMPO    | Hora de dedicación  | 20€            | 600 - 1000 | 12.000€ - 20.000€ |                                |
| Multas    | Según protocolo     | 8.000€         | 1          | 8.000 €           |                                |
| Ingresos  | Reputación          | 10.000€ - 40%  | 1          | 6.000€            | Consultoría, afiliados, ads... |

# CONCLUSIÓN

- Website con uso normal:
  - **Beneficios:** 1.000€ - 4.000€
- Hackeado
  - **Pérdidas:** - (22.000€ - 14.000€)
- **Coste de medidas de seguridad** -> 100€ - 300€
  - > Diferencia-> - **(21.000€ - 10.000€)**





## EJEMPLO 2

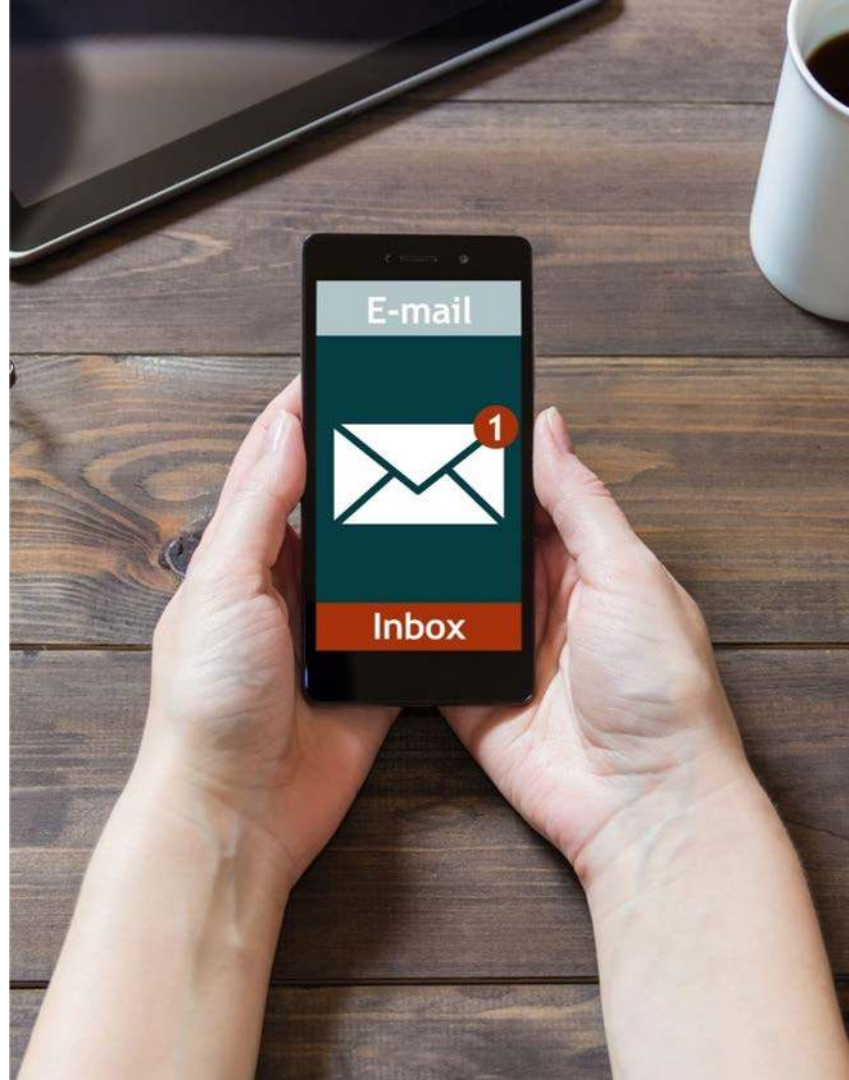
### E-Commerce

---



# Datos que se recopilan

- Clientes
  - Nombres y apellidos
  - Correo
  - Teléfono
  - Medios de pago
  - Dirección física
  - DNI o similares
  - Edad
- Cookies / Analíticas
- Usuario y contraseña



# Ingresos - Costes -> Beneficios:

~ 50.000€ - 100.000€

| Paquete   | Concepto            | Precio (rango)    | Cantidad   | Total              | Notas                          |
|-----------|---------------------|-------------------|------------|--------------------|--------------------------------|
| Sitio Web | Hosting + dominio   | 100€ - 200€       | 1          | 100€ - 200€        |                                |
|           | Diseño              | 0€ - 3.000€       | 1          | 0€ - 3.000€        |                                |
|           | Plugins / servicios | 300€ - 15.000€    | 1          | 300€ - 15.000€     | SEO, Newsletter, forms...      |
|           | Otros costes        | 50.000€ - 80.000€ | 1          | 80.000€ - 100.000€ | Manipulación, sueldos, imp...  |
| TIEMPO    | Hora de dedicación  | 20€               | 900 - 1500 | 18.000€ - 30.000€  |                                |
| Ingresos  | Reputación          | 20.000€           | 1          | 20.000€            | Consultoría, afiliados, ads... |
|           | Ventas              | 200.000 €         | 1          | 200.000€           |                                |

## Y qué pasa si te hackean...

| Concepto                         | Tipo           |
|----------------------------------|----------------|
| Entender qué ha pasado           | Tiempo         |
| Implementar Medidas de Seguridad | Tiempo, Dinero |
| Servicio para limpiar el sitio   | Tiempo, Dinero |
| Comunicación a la AEPD < 72h     | Tiempo         |
| Estudio de riesgo e impacto      | Tiempo         |



## Y si la severidad del hackeo es alta...

| Concepto                                                                                 | Tipo           |
|------------------------------------------------------------------------------------------|----------------|
| Notificar a clientes / Usuarios                                                          | Tiempo         |
| Lidiar con las quejas y comunicaciones (Demandas?)                                       | Tiempo/Dinero  |
| <b>Estrés</b>                                                                            | Tiempo, Dinero |
| <b>Multa GDPR</b> ( $\leq 10$ mill€ o 2% de <b>ingresos</b> ), si siguen el protocolo    | Tiempo, Dinero |
| <b>Multa GDPR</b> ( $\leq 20$ mill€ o 4% de <b>ingresos</b> ), si no siguen el protocolo | Tiempo, Dinero |

# Ingresos - Costes -> Beneficios:

~ -(270.000€ - 300.000€)

| Paquete   | Concepto            | Precio (rango)    | Cantidad | Total              | Notas                         |
|-----------|---------------------|-------------------|----------|--------------------|-------------------------------|
| Sitio Web | Hosting + dominio   | 100€ - 200€       | 1        | 100€ - 200€        |                               |
|           | Diseño              | 0€ - 3.000€       | 1        | 0€ - 3.000€        |                               |
|           | Plugins / servicios | 300€ - 15.000€    | 1        | 300€ - 15.000€     | SEO, Newsletter, forms...     |
|           | Otros costes        | 50.000€ - 80.000€ | 1        | 80.000€ - 100.000€ | Manipulación, sueldos, imp... |

|        |                    |          |            |                   |  |
|--------|--------------------|----------|------------|-------------------|--|
| TIEMPO | Hora de dedicación | 20€      | 1200- 1700 | 24.000€ - 34.000€ |  |
| MULTAS | Según protocolo    | 300.000€ | 1          | 300.000€          |  |

|          |            |               |   |          |                                |
|----------|------------|---------------|---|----------|--------------------------------|
| Ingresos | Reputación | 20.000€ - 40% | 1 | 12.000€  | Consultoría, afiliados, ads... |
|          | Ventas     | 200k€ - 40%   | 1 | 120.000€ |                                |

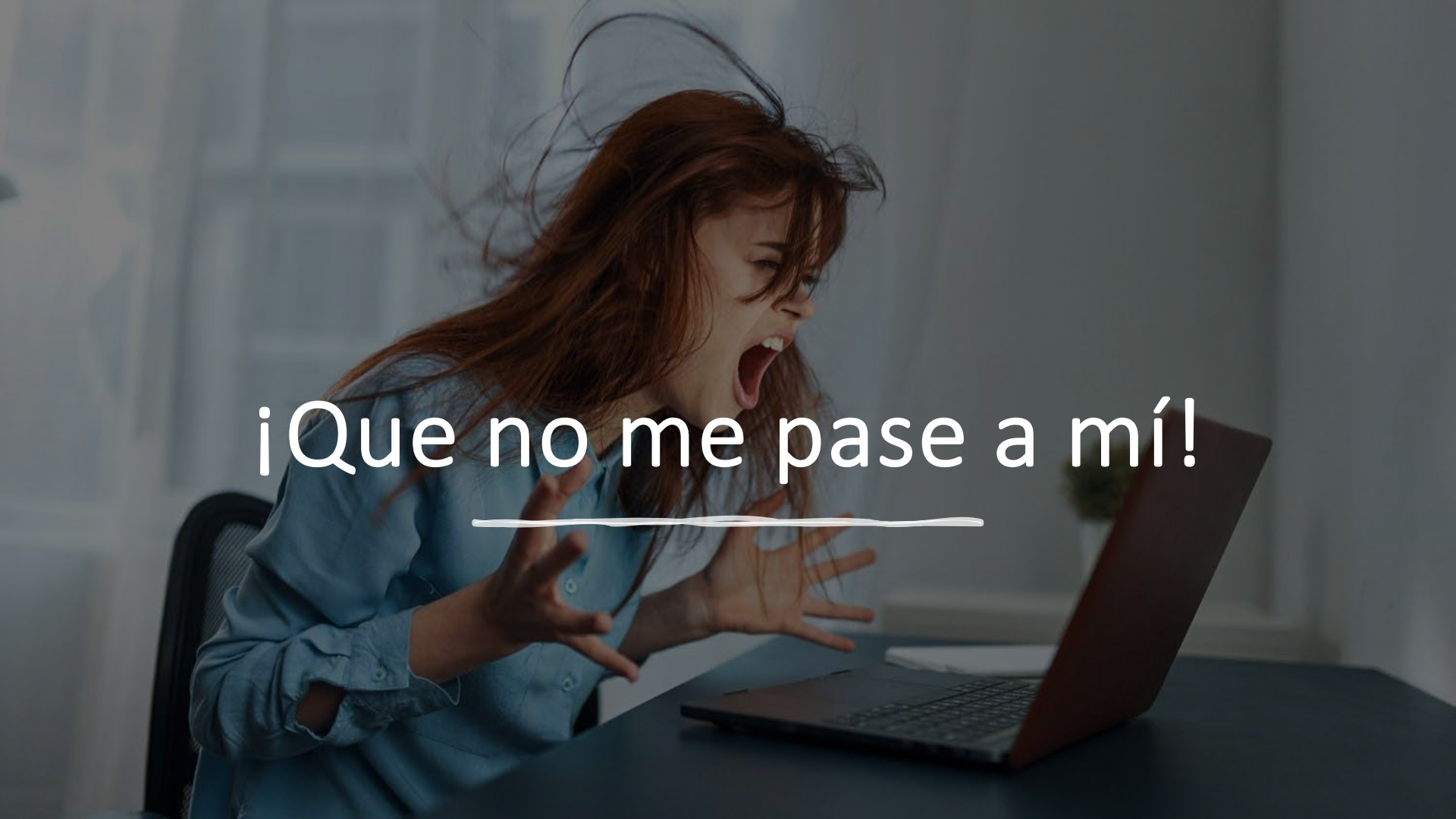
# CONCLUSIÓN

- E-commerce con uso normal:
  - **Beneficios:** 50.000€ - 100.000€
- Hackeado
  - **Pérdidas:** - (270.000€ - 300.000€)
- **Coste de medidas de seguridad** -> 500€ - 1.000€

|                                                                                 |           |                                                                                              |            |             |                                           |                                                                                                              |                                                                                   |                      |
|---------------------------------------------------------------------------------|-----------|----------------------------------------------------------------------------------------------|------------|-------------|-------------------------------------------|--------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|----------------------|
|    | ETid-2039 | <br>HUNGARY   | 2023-06-22 | 205,000     | Digi Telecommunications and Services Ltd. | Art. 5 (1) a) GDPR, Art. 32 (1), (2) GDPR                                                                    | Insufficient technical and organisational measures to ensure information security | <a href="#">link</a> |
|  | ETid-2038 | <br>SPAIN   | 2023-08-30 | 140,000     | GENERAL LOGISTICS SYSTEMS SPAIN, S.A.     | Art. 6 GDPR                                                                                                  | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2037 | <br>ITALY   | 2023-07-18 | 1,000       | Prodav srl                                | Art. 5 GDPR, Art. 13 GDPR, Art. 114 Codice della privacy                                                     | Non-compliance with general data processing principles                            | <a href="#">link</a> |
|  | ETid-2036 | <br>SPAIN   | 2023-09-07 | 70,000      | SUMINISTRADOR IBÉRICO DE ENERGÍA, S.L.    | Art. 6 (1) GDPR                                                                                              | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2035 | <br>SPAIN   | 2023-09-21 | 4,000       | Private individual                        | Art. 6 GDPR                                                                                                  | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2034 | <br>SPAIN   | 2023-09-21 | 300         | Private individual                        | Art. 5 (1) c) GDPR                                                                                           | Non-compliance with general data processing principles                            | <a href="#">link</a> |
|  | ETid-2033 | <br>ITALY   | 2023-07-06 | 10,000      | AcegasApsAmga SpA                         | Art. 5 (1) a) GDPR, Art. 12 GDPR, Art. 15 GDPR                                                               | Insufficient fulfilment of data subjects rights                                   | <a href="#">link</a> |
|  | ETid-2032 | <br>IRELAND | 2023-09-01 | 345,000,000 | TikTok Limited                            | Art. 5 (1) c), 5 (1) f) GDPR, Art. 12 (1) GDPR, Art. 13 (1) e) GDPR, Art. 24 (1) GDPR, Art. 25 (1), (2) GDPR | Non-compliance with general data processing principles                            | <a href="#">link</a> |

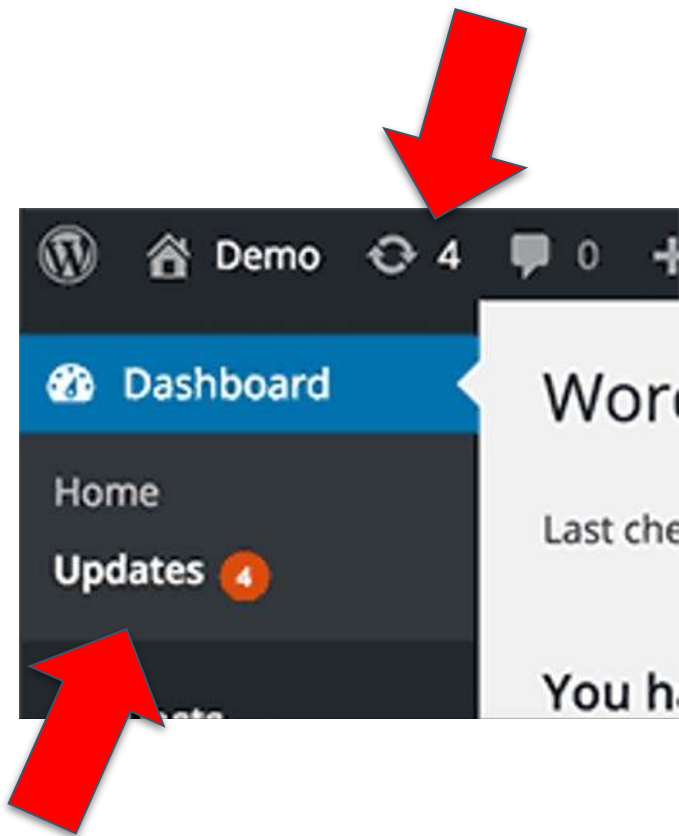
|                                                                                 |           |                                                                                              |            |             |                                           |                                                                                                              |                                                                                   |                      |
|---------------------------------------------------------------------------------|-----------|----------------------------------------------------------------------------------------------|------------|-------------|-------------------------------------------|--------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|----------------------|
|    | ETid-2039 | <br>HUNGARY   | 2023-06-22 | 205,000     | Digi Telecommunications and Services Ltd. | Art. 5 (1) a) GDPR, Art. 32 (1), (2) GDPR                                                                    | Insufficient technical and organisational measures to ensure information security | <a href="#">link</a> |
|  | ETid-2038 | <br>SPAIN   | 2023-08-30 | 140,000     | GENERAL LOGISTICS SYSTEMS SPAIN, S.A.     | Art. 6 GDPR                                                                                                  | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2037 | <br>ITALY   | 2023-07-18 | 1,000       | Prodav srl                                | Art. 5 GDPR, Art. 13 GDPR, Art. 114 Codice della privacy                                                     | Non-compliance with general data processing principles                            | <a href="#">link</a> |
|  | ETid-2036 | <br>SPAIN   | 2023-09-07 | 70,000      | SUMINISTRADOR IBÉRICO DE ENERGÍA, S.L.    | Art. 6 (1) GDPR                                                                                              | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2035 | <br>SPAIN   | 2023-09-21 | 4,000       | Private individual                        | Art. 6 GDPR                                                                                                  | Insufficient legal basis for data processing                                      | <a href="#">link</a> |
|  | ETid-2034 | <br>SPAIN   | 2023-09-21 | 300         | Private individual                        | Art. 5 (1) c) GDPR                                                                                           | Non-compliance with general data processing principles                            | <a href="#">link</a> |
|  | ETid-2033 | <br>ITALY   | 2023-07-06 | 10,000      | AcegasApsAmga SpA                         | Art. 5 (1) a) GDPR, Art. 12 GDPR, Art. 15 GDPR                                                               | Insufficient fulfilment of data subjects rights                                   | <a href="#">link</a> |
|  | ETid-2032 | <br>IRELAND | 2023-09-01 | 345,000,000 | TikTok Limited                            | Art. 5 (1) c), 5 (1) f) GDPR, Art. 12 (1) GDPR, Art. 13 (1) e) GDPR, Art. 24 (1) GDPR, Art. 25 (1), (2) GDPR | Non-compliance with general data processing principles                            | <a href="#">link</a> |



A woman with long brown hair, wearing a light blue button-down shirt, is sitting at a dark desk. She is leaning forward with her mouth wide open in a scream, and her hands are raised in front of her, palms facing forward. Her hair is blowing in the wind. In front of her is a laptop. The background is a blurred office setting with a window and some plants.

¡Que no me pase a mí!

# La importancia de ACTUALIZAR



- Tapas agujeros de seguridad (**Security patches**)
- Los parches de seguridad aparecen después del exploit
- Sobreescribes con **código limpio**
- >70% de las infecciones son debidas a **plugins/temas desactualizados**.

**¡RECUERDA!**

**$\forall$  COSTO Web caída**

**<**

**$\forall$  COSTO Web hackeada**



# La importancia de LAS CONTRASEÑAS & 2FA

Factores de **AUTENTICACIÓN**:

- Algo que el usuario **es**  
(huella digital, identificación facial,...).
- Algo que el usuario **tiene**  
(teléfono celular, yubikey, ...)
- Algo que el usuario **sabe**  
(contraseña, PIN, ...).







## Medidas Proactivas



Reducir administradores, plugins y plantillas



Copias de seguridad



Actualizaciones



Invertir en un buen Hosting y en Seguridad



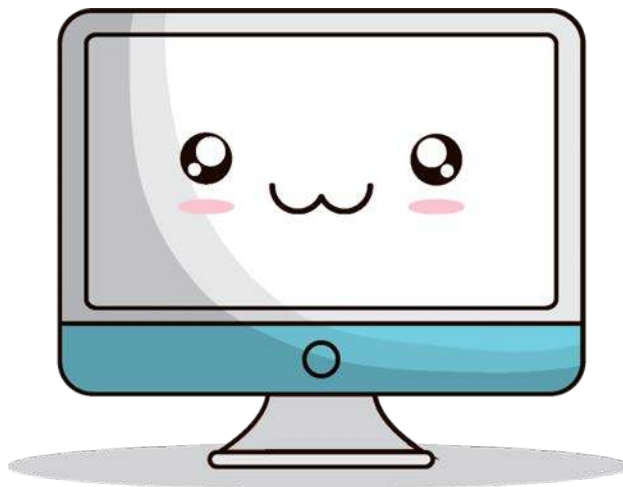
Web Application Firewall

# Mi combo ganador



- **SSL** (free)
- **Sucuri** (monitor + Firewall externo):  
200€/año
- **SolidWP Security** (100€/año)
- **Updraft** (70€/año)
- **Plugins:**
  - **WP Fail2ban**
  - **Two Factor Authentication**
  - **CAPTCHA Plugin**

# BONUS: INVIERTE EN



# La importancia de tener un buen HOSTING



- Primera capa remota de seguridad
- Sistema de soporte
- Copias de seguridad
- Mantienen el software dependiente (Servidor Web, Base de Datos, Intérprete PHP, etc.) y el hardware.





## REFERENCIAS:

### Por si quieres saber más...



- GDPR-INFO

<https://gdpr-info.eu/issues/personal-data/>

- GDPR GUIDE for business

<https://www.algoodbody.com/media/TheGDPR-AGuideforBusinesses1.pdf>

- [EnforcementTracker.com](https://enforcementtracker.com) - Seguimiento de multas GDPR.
- Websitesetup.org - How much does a web cost in 2022

<https://websitesetup.org/how-much-does-a-website-cost>

- PurpleSec.us

<https://purplesec.us/resources/cyber-security-statistics/>

- AEPD - Guia Brechas de Seguridad

<https://www.aepd.es/es/documento/guia-brechas-seguridad.pdf>

A black and white photograph showing the back of a person. The person is wearing a dark-colored t-shirt. The text "Everybody needs a hacker" is printed in white on the upper back of the shirt. The person's hair is visible at the top of the frame, and the background is out of focus.

Everybody needs a hacker



¡Muchas GRACIAS!

Ahora...

¡PREGUNTAS!

